White Team 7:30AM Intrusion Report

Team 39

:skullpray:

Time Detected: 7:35
System: MGMT
Details: RedTeam was able to get on to our MGMT box and capture MGMT Bus service and MGMT Train service flags. In the vehicles.py file, the route for getting the flag requires all the vehicles to be stopped (so vehicle.status is False). Otherwise, the flag is not earned. The status of vehicles is controlled by another endpoint in vehicles.py by this route was not protected with authentication. Therefore, when the attackers stop all the vehicles, they have 'earned' the flag without needing to authenticate and that allowed them to get the flag.

Supporting evidence:
This is the attack chain for both the Bus and Train service flags.

```
[root@mgmt app]# grep -R "12.110.206/201" /var/log
Binary file /var/log/pcp/pmlogger/mgmt.team39.isucdc.com/20260221.00.10.1 matches
[root@mgmt app]# grep -R "12.110.206.201" /var/log
Binary file /var/log/pcp/pmlogger/mgmt.team39.isucdc.com/20260221.00.10.1 matches
/var/log/messages:Feb 21 07:32:05 mgmt flask[3428387]: 12.110.206.201 - - [21/Feb/2026 07:32:05] "#033[31m#033[1mPOST /auth/login HTTP/1.1#033[0m" 401 -
/var/log/messages:Feb 21 07:32:05 mgmt flask[3428387]: 12.110.206.201 - - [21/Feb/2026 07:32:05] "#033[31m#033[1mGET /payment-info/ HTTP/1.1#033[0m" 401 -
/var/log/messages:Feb 21 07:32:05 mgmt flask[3428387]: 12.110.206.201 - - [21/Feb/2026 07:32:05] "GET /vehicles/ HTTP/1.1" 200 -
/var/log/messages:Feb 21 07:32:05 mgmt flask[3428387]: 12.110.206.201 - - [21/Feb/2026 07:32:05] "POST /vehicles/0ab054ac-778e-4578-8933-d0bcc16701fa HTTP/1.1"
200 -
/var/log/messages:Feb 21 07:32:05 mgmt flask[3428387]: 12.110.206.201 - - [21/Feb/2026 07:32:05] "POST /vehicles/387cb109-7057-452a-ac73-b7518e947efc HTTP/1.1"
200 -
/var/log/messages:Feb 21 07:32:05 mgmt flask[3428387]: 12.110.206.201 - - [21/Feb/2026 07:32:05] "POST /vehicles/6a53d7be-5742-40d7-97ab-6215bed5d9b5 HTTP/1.1"
200 -
/var/log/messages:Feb 21 07:32:05 mgmt flask[3428387]: 12.110.206.201 - - [21/Feb/2026 07:32:05] "POST /vehicles/c5f60fcc-fc14-4e13-8989-09e3598b2dcc HTTP/1.1"
200 -
/var/log/messages:Feb 21 07:32:05 mgmt flask[3428387]: 12.110.206.201 - - [21/Feb/2026 07:32:05] "POST /vehicles/ce83fa1f-786f-4637-8833-daebf1603401 HTTP/1.1"
200 -
/var/log/messages:Feb 21 07:32:05 mgmt flask[3428387]: 12.110.206.201 - - [21/Feb/2026 07:32:05] "POST /vehicles/d351dac7-43ae-4c46-bad9-f40df35ca5ed HTTP/1.1"
200 -
/var/log/messages:Feb 21 07:32:05 mgmt flask[3428387]: 12.110.206.201 - - [21/Feb/2026 07:32:05] "POST /vehicles/f3af1b4d-8b45-46c9-8807-15fc39f0bd87 HTTP/1.1"
200 -
/var/log/messages:Feb 21 07:32:05 mgmt flask[3428387]: 12.110.206.201 - - [21/Feb/2026 07:32:05] "POST /vehicles/ffac9a5f-ecde-42e8-a3ec-e8f442b79009 HTTP/1.1"
200 -
/var/log/messages:Feb 21 07:32:05 mgmt flask[3428387]: 12.110.206.201 - - [21/Feb/2026 07:32:05] "GET /vehicles/bus/flag HTTP/1.1" 200 -
/var/log/messages:Feb 21 07:32:05 mgmt flask[3428387]: 12.110.206.201 - - [21/Feb/2026 07:32:05] "POST /vehicles/3e409a45-3b1e-4661-8cd1-1f67737f3f04 HTTP/1.1"
200 -
/var/log/messages:Feb 21 07:32:06 mgmt flask[3428387]: 12.110.206.201 - - [21/Feb/2026 07:32:06] "POST /vehicles/837b1b7e-9fb8-4de5-9654-47d9b5c141e5 HTTP/1.1"
200 -
/var/log/messages:Feb 21 07:32:06 mgmt flask[3428387]: 12.110.206.201 - - [21/Feb/2026 07:32:06] "POST /vehicles/ae962416-fefc-420d-af02-aa478c8880c4 HTTP/1.1"
200 -
/var/log/messages:Feb 21 07:32:06 mgmt flask[3428387]: 12.110.206.201 - - [21/Feb/2026 07:32:06] "POST /vehicles/c6de83f7-d539-4d40-905a-4fea924fc011 HTTP/1.1"
200 -
/var/log/messages:Feb 21 07:32:06 mgmt flask[3428387]: 12.110.206.201 - - [21/Feb/2026 07:32:06] "POST /vehicles/c0177914-d1f0-4371-09fe-72a14453b664 HTTP/1.1"
200 -
/var/log/messages:Feb 21 07:32:06 mgmt flask[3428387]: 12.110.206.201 - - [21/Feb/2026 07:32:06] "POST /vehicles/e5ac8f47-d163-4abc-9b71-eb155c5794f3 HTTP/1.1"
200 -
/var/log/messages:Feb 21 07:32:06 mgmt flask[3428387]: 12.110.206.201 - - [21/Feb/2026 07:32:06] "GET /vehicles/train/flag HTTP/1.1" 200 -
[root@mgmt app]# _
```

These are the sections in the code that were vulnerable to this attack:

```python
@bp.route("/<vehicle_id>", methods=["POST"])
def update_vehicle(vehicle_id):
    vehicle = Vehicle.query.get(vehicle_id)
    data = request.get_json()
    status = data.get("status")
    stop = data.get("current_stop")
    x = data.get("x")
    y = data.get("y")
    count = data.get("passenger_count")
    capacity = data.get("max_capacity")

    if not vehicle:
        return jsonify({"error": "Vehicle not found"}), 404

    if stop is not None:
        for i, s in enumerate(vehicle.route.stops):
            if s["name"] == stop:
                stop = i
                break
        else:
            return jsonify({"error": "No such stop"}), 404

        # flip direction for non-looping routes at end of route
        if not vehicle.route.looping and (
            (not vehicle.reverse and stop >= len(vehicle.route.stops) - 1)
            or (vehicle.reverse and stop == 0)
        ):
            print("REVERSE")
            vehicle.reverse = not vehicle.reverse

    vehicle.status = status if status is not None else vehicle.status
    vehicle.current_stop = stop if stop is not None else vehicle.current_stop
    vehicle.x = x if x is not None else vehicle.x
    vehicle.y = y if y is not None else vehicle.y
    vehicle.passenger_count = count if count is not None else vehicle.passenger_count
    vehicle.max_capacity = capacity if capacity is not None else vehicle.max_capacity

    try:
        db.session.commit()
        return jsonify({"message": "Vehicle updated successfully"}), 200
    except:
        return jsonify({"error": "Failed to update route"}), 500
```

```python
##############################################################################
#    You MUST NOT modify this code. External users MUST be able to          #
#    retrieve the actual flags as stored in IScorE if the condition is met. #
##############################################################################
@bp.route("/<type>/flag", methods=["GET"])
def get_flag(type):
    vehicles = Vehicle.query.filter_by(type=type).all()

    for vehicle in vehicles:
        if vehicle.status:
            return jsonify({"error": "Flag not earned"})
    return jsonify({f"{type}_service_flag": Config.FLAGS[f"{type}_service_flag"]})


##############################################################################
```

Mitigation Actions taken:

We added session check that checks if the user is logged in as an admin. This ensures that no other users can change the status of the buses and trains. This will then stop them from receiving the flags or any other data.

```
@bp.route("/<vehicle_id>", methods=["POST"])
def update_vehicle(vehicle_id):
    if not session["is_admin"]:
        return 404
    vehicle = Vehicle.query.get(vehicle_id)
    data = request.get_json()
    status = data.get("status")
    stop = data.get("current_stop")
    x = data.get("x")
    y = data.get("y")
```

No other intrusions detected:

We have yet to detect any suspicious activity any other systems. Looking at our FailToBan logs on the WWW linux system, we can see that RedTeam has been attempting to brute force into our systems, but they have yet to succeed.

```
2026-02-21 06:31:15,846 fail2ban.filter         [1754292]: INFO    [sshd] Found 49.10.219.164 - 2026-02-21 06:31:15
2026-02-21 06:31:46,689 fail2ban.filter         [1754292]: INFO    [sshd] Found 12.110.206.140 - 2026-02-21 06:31:46
2026-02-21 06:31:49,285 fail2ban.filter         [1754292]: INFO    [sshd] Found 12.110.206.140 - 2026-02-21 06:31:48
2026-02-21 06:52:14,009 fail2ban.filter         [1754292]: INFO    [sshd] Found 12.110.206.226 - 2026-02-21 06:52:13
2026-02-21 06:52:16,021 fail2ban.filter         [1754292]: INFO    [sshd] Found 12.110.206.226 - 2026-02-21 06:52:15
2026-02-21 06:52:16,023 fail2ban.filter         [1754292]: INFO    [sshd] Found 12.110.206.226 - 2026-02-21 06:52:15
2026-02-21 06:55:22,347 fail2ban.filter         [1754292]: INFO    [sshd] Found 12.110.206.226 - 2026-02-21 06:55:21
2026-02-21 06:55:23,898 fail2ban.filter         [1754292]: INFO    [sshd] Found 12.110.206.226 - 2026-02-21 06:55:23
2026-02-21 06:55:24,668 fail2ban.actions        [1754292]: NOTICE  [sshd] Ban 12.110.206.226
2026-02-21 07:18:03,469 fail2ban.filter         [1754292]: INFO    [sshd] Found 12.110.206.140 - 2026-02-21 07:18:03
2026-02-21 07:18:05,014 fail2ban.filter         [1754292]: INFO    [sshd] Found 12.110.206.140 - 2026-02-21 07:18:05
2026-02-21 07:31:13,747 fail2ban.actions        [1754292]: NOTICE  [sshd] Unban 49.10.219.164
[root@mgmt icdc26-backend-mgmt]# _
```

Looking at the network traffic for the Windows systems, there have been no foreign IPs detected.

*Ethernet 2

File Edit View Go Capture Analyze Statistics Telephony Wireless Tools Help

dns

No.	Time	Source	Destination	Protocol	Length	Info
25	3.104968	192.168.1.50	192.168.1.10	DNS	82	Standard query 0x0d93 A mgmt.team39.isucdc.com
26	3.104968	192.168.1.50	192.168.1.10	DNS	82	Standard query 0xbc85 AAAA mgmt.team39.isucdc.com
27	3.105684	192.168.1.10	192.168.1.50	DNS	98	Standard query response 0x0d93 A mgmt.team39.isucdc.com A 192.168.1.30
28	3.105729	192.168.1.10	192.168.1.50	DNS	132	Standard query response 0xbc85 AAAA mgmt.team39.isucdc.com SOA ad.team39.isucdc.com
29	3.114848	192.168.1.50	192.168.1.10	DNS	82	Standard query 0x920a A mgmt.team39.isucdc.com
30	3.114848	192.168.1.50	192.168.1.10	DNS	82	Standard query 0x8a04 AAAA mgmt.team39.isucdc.com
31	3.115687	192.168.1.10	192.168.1.50	DNS	132	Standard query response 0x8a04 AAAA mgmt.team39.isucdc.com SOA ad.team39.isucdc.com
32	3.115701	192.168.1.10	192.168.1.50	DNS	98	Standard query response 0x920a A mgmt.team39.isucdc.com A 192.168.1.30
49	3.708953	192.168.1.30	192.168.1.10	DNS	80	Standard query 0xd934 A ad.team39.isucdc.com
50	3.708953	192.168.1.30	192.168.1.10	DNS	80	Standard query 0x35cf AAAA ad.team39.isucdc.com
51	3.709812	192.168.1.10	192.168.1.30	DNS	127	Standard query response 0x35cf AAAA ad.team39.isucdc.com SOA ad.team39.isucdc.com
52	3.709820	192.168.1.10	192.168.1.30	DNS	96	Standard query response 0xd934 A ad.team39.isucdc.com A 192.168.1.10
119	4.101543	192.168.1.50	192.168.1.10	DNS	82	Standard query 0x1c9b A mgmt.team39.isucdc.com
120	4.101543	192.168.1.50	192.168.1.10	DNS	82	Standard query 0x3492 AAAA mgmt.team39.isucdc.com
121	4.102261	192.168.1.10	192.168.1.50	DNS	132	Standard query response 0x3492 AAAA mgmt.team39.isucdc.com SOA ad.team39.isucdc.com
122	4.102265	192.168.1.10	192.168.1.50	DNS	98	Standard query response 0x1c9b A mgmt.team39.isucdc.com A 192.168.1.30
123	4.111169	192.168.1.50	192.168.1.10	DNS	82	Standard query 0xad09 A mgmt.team39.isucdc.com

```
> Frame 1: 82 bytes on wire (656 bits), 82 bytes captured (656 bits) on interface \Device\
> Ethernet II, Src: ProxmoxServe_5c:b2:21 (bc:24:11:5c:b2:21), Dst: ProxmoxServe_55:52:05
> Internet Protocol Version 4, Src: 192.168.1.50, Dst: 192.168.1.10
> User Datagram Protocol, Src Port: 37656, Dst Port: 53
> Domain Name System (query)

0000  bc 24 11 55 52 05 bc 24  11 5c b2 21 08 00 45 00   ·$·UR··$ ·\·!··E·
0010  00 44 f0 78 40 00 40 11  c6 a3 c0 a8 01 32 c0 a8   ·D·x@·@· ·····2··
0020  01 0a 93 18 00 35 00 30  62 3b 8b d2 01 00 00 01   ·····5·0 b;******
0030  00 00 00 00 00 00 04 6d  67 6d 74 06 74 65 61 6d   *******m gmt·team
0040  33 39 06 69 73 75 63 64  63 03 63 6f 6d 00 00 01   39·isucd c·com···
0050  00 01                                              ··
```